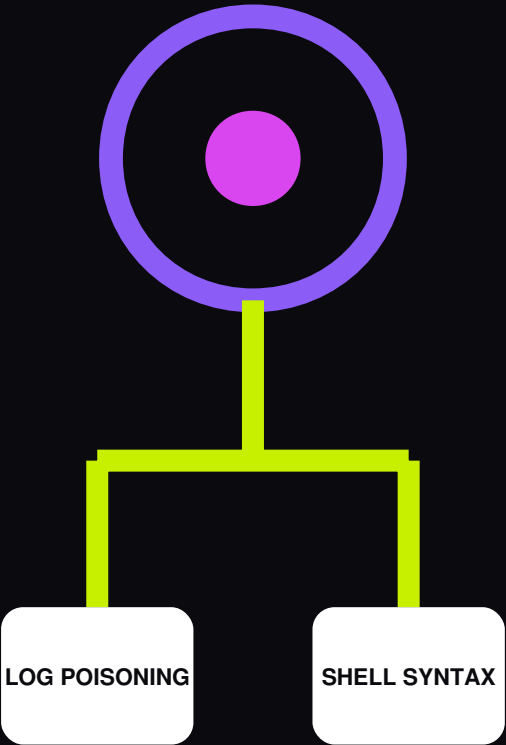


NETSCALER LOG POISONING SHELL INJECTION

Detects the documented CVE-2026-88771 log-poisoning grammar by combining fake pitboss/NSPPE failure text with shell metacharacters in NetScaler logs.

PRODUCTION CANDIDATE

CONFIDENCE: HIGH



EVIDENCE BEFORE ALERTING

REPORT DATE

5 October 2026

STATUS

Untested implementation
sketch

PRIMARY PLATFORM

Microsoft Sentinel

OPERATIONAL VALUE

10.0 / 10



EXECUTIVE ASSESSMENT

Decision, confidence and evidence boundary.

ASSESSMENT

OPERATIONAL VALUE

10.0

Detects the documented CVE-2026-88771 log-poisoning grammar by combining fake pitboss/NSPPE failure text with shell metacharacters in NetScaler logs.

STATUS

Production candidate

Untested implementation sketch; Confidence High.

2primary tables

0joins

0secondary rules

2validation gates

Evidence boundary

A result is strong evidence of an exploit-shaped log-poisoning attempt. It does not prove that the deferred maintenance script consumed the record, that a command executed, or that the appliance was compromised.



BEHAVIOR AND EVIDENCE

Observed facts separated from analytical scope.

MECHANICS

Source-supported fact

- 1 Citrix confirms exploitation of CVE-2026-88771 on unmitigated NetScaler deployments; the default configuration is affected.
- 2 watchTowr reproduced pre-authentication root command execution through attacker-controlled text written to NetScaler AAA and SSLVPN logs.
- 3 The vulnerable ns_monupload_err.pl processing is deferred and may consume the poisoned log record hours after the initial request.

Detection hypothesis

If an attacker attempts CVE-2026-88771 using the documented mechanism, centralized NetScaler logs should preserve the fake pitboss/NSPPE failure grammar and adjacent shell-control syntax. Distinction relies on the complete combined pattern and authorized-test context.

Unconfirmed elements

A result is strong evidence of an exploit-shaped log-poisoning attempt. It does not prove that the deferred maintenance script consumed the record, that a command executed, or that the appliance was compromised.

Logic: Exploit-specific log grammar and shell-control syntax **ATT&CK:** T1190 / T1059.004



TELEMETRY CONTRACT

Collection prerequisites and field reliability.

TELEMETRY

REQUIRED

NetScaler ns.log, AAA, SSLVPN, or CEF records forwarded without truncating or removing the attacker-controlled login, header, or request value.

OPTIONAL ENRICHMENT

NetScaler asset/build inventory, external source IP, requested endpoint, raw appliance logs, core/crash artifacts, file integrity results, process evidence, outbound connections, and approved security-test records.

Fields	Reliability	Use
TimeGenerated	Documented	Query or triage
SyslogMessage	Documented	Query or triage
Message, AdditionalExtensions	Documented	Query or triage
DeviceCustomString1-6	Documented	Query or triage
Computer, HostIP, DeviceAddress	Documented	Query or triage
ProcessName / DeviceProcessName	Environment-dependent	Query or triage
Full untruncated exploit value	Environment-dependent	Query or triage

Excluded

No command-execution outcome, webshell inference, actor attribution, generic IOC dependency, or undocumented cross-SIEM mapping is used.



PRIMARY KQL

Direct source-supported conditions with investigable output.

PRODUCTION

STATUS

Production candidate — Untested implementation sketch

```
KQL -- UNTESTED

// MITRE ATT&CK: T1190, T1059.004
// Production candidate - Untested implementation sketch
// CVE: CVE-2026-88771
// Primary platform: Microsoft Sentinel / Log Analytics
// Required telemetry: NetScaler ns.log/AAA/SSLVPN records forwarded to Syslog
// or CEF/CommonSecurityLog without truncating the attacker-controlled value.
// Detection boundary: identifies the exploit-shaped log-poisoning string documented
// by watchTowr. A match is strong evidence of an exploitation attempt, but does not
// prove that ns_monupload_err.pl later processed the record or that commands ran.
let Lookback = 14d;
let ExploitGrammar = @"(?i)pitboss.{0,120}(?:PPE.{0,40})?(?:unexpectedly\s+died|missed\s+too\s+many\s+heartbeats).{0,120}NSPPE.{0,200}(?:;|'|\"|\(|\)|\&&|>|<|<);
let NetScalerLogs = union isfuzzy=true
  (Syslog
    | project
      TimeGenerated,
      SourceTable="Syslog",
      Device=Computer,
      SourceHostIP=HostIP,
      LogProcess=ProcessName,
      RawMessage=SyslogMessage,
      _ResourceId),
  (CommonSecurityLog
    | project
      TimeGenerated,
      SourceTable="CommonSecurityLog",
      Device=coalesce(DeviceName, Computer),
      SourceHostIP=DeviceAddress,
      LogProcess=DeviceProcessName,
      RawMessage=strcat(
        coalesce(Message, ""), " ",
        coalesce(AdditionalExtensions, ""), " ",
        coalesce(DeviceCustomString1, ""), " ",
        coalesce(DeviceCustomString2, ""), " ",
        coalesce(DeviceCustomString3, ""), " ",
        coalesce(DeviceCustomString4, ""), " ",
        coalesce(DeviceCustomString5, ""), " ",
        coalesce(DeviceCustomString6, "")
      ),
      _ResourceId);
NetScalerLogs
| where TimeGenerated >= ago(Lookback)
| where RawMessage has all ("pitboss", "NSPPE")
| where RawMessage matches regex ExploitGrammar
| extend
  HasShellSeparator = RawMessage has any (";", " ", "$(", "|", "&", ">", "<"),
  HasAAALogContext = RawMessage has any (
    "AAAD API: sending login req",
    "process kernel socket: call to authenticate user",
    "AAAD RESP: received resp"
  )
| project
  TimeGenerated,
  SourceTable,
  Device,
  SourceHostIP,
  LogProcess,
  HasAAALogContext,
  HasShellSeparator,
  RawMessage,
  _ResourceId
| order by TimeGenerated desc
```

WINDOW	THRESHOLD	TABLES	KEY
14 days; incident-response hunt scope	Single complete exploit grammar	Syslog + CommonSecurityLog	pitboss + failure text + NSPPE + shell token



TRIAGE AND TUNING

Human validation before response.

WORKFLOW

1

Preserve

Retain the complete raw NetScaler record, table, normalized message, source host/IP, process context, timestamp, and resource identifier.

2

Confirm

Confirm appliance build, exposure, log origin, source IP, requested surface, approved testing, and the exact encoded/decoded value.

3

Enrich

NetScaler asset/build inventory, external source IP, requested endpoint, raw appliance logs, core/crash artifacts, file integrity results, process evidence, outbound connections, and approved security-test records.

4

Scope

Review appliance files, custom web paths, configuration changes, process/core evidence, outbound traffic, and adjacent authentication activity.

Expected benign overlap

Authorized exposure validation, red-team activity, or synthetic parser testing. The complete fake pitboss/NSPPE failure grammar plus a shell-control token is not expected in normal authentication activity.

Response boundary

A result is strong evidence of an exploit-shaped log-poisoning attempt. It does not prove that the deferred maintenance script consumed the record, that a command executed, or that the appliance was compromised.



VALIDATION GATES

Controlled tests and cross-SIEM limits.

QUALITY CONTROL

Validation steps

- 1. Replay a benign synthetic log record into a test collector without invoking the public exploit against production.
- 2. Verify the full attacker-controlled value survives NetScaler forwarding, CEF normalization, ingestion, and retention.
- 3. Exercise encoded and decoded representations, spacing, case variation, each documented failure phrase, and multiple shell operators.
- 4. Confirm ordinary failed logins, rate limiting, service-state messages, and legitimate NSPPE crashes do not match.

Decision criteria

Success: The synthetic exploit-shaped record produces one complete result while ordinary authentication and crash records remain silent.

Rejection: The forwarded message truncates the required grammar, or normal NetScaler operations reproduce the complete condition.

Failure: Missing off-box logs, CEF field relocation, encoding differences, message truncation, alternate poisoning grammar, or expired retention.

Platform	Decision	Missing evidence
Microsoft Sentinel	Production candidate	Exploit-shaped log replay
Splunk	No reliable implementation	Index, sourcetype, parser, sample
Chronicle	No reliable implementation	Parser and exact UDM mapping



CONCLUSION AND REFERENCES

Coverage statement and document control.

FINAL

CONCLUSION

Production candidate

Detects the documented CVE-2026-88771 log-poisoning grammar by combining fake pitboss/NSPPE failure text with shell metacharacters in NetScaler logs.

A result is strong evidence of an exploit-shaped log-poisoning attempt. It does not prove that the deferred maintenance script consumed the record, that a command executed, or that the appliance was compromised.

MITRE ATT&CK

T1190 / T1059.004

References

1. Citrix - CTX697096 - published 27 Sep 2026
2. NetScaler Cyber Threat Intelligence - CVE-2026-88771 through CVE-2026-88778 - updated 30 Sep 2026
3. watchTower Labs - NetScaler PreAuth Command Injection CVE-2026-88771 - 28 Sep 2026
4. UK NCSC - Exploitation of vulnerabilities affecting NetScaler - 28 Sep 2026
5. Microsoft Learn - Syslog and CommonSecurityLog schemas
6. MITRE ATT&CK - T1190 and T1059.004

Document control

English dossier. No customer data. URLs are defanged in references.txt. HTML and rendering assets remain private.